

AI Vendor Risk Questionnaire

Model Transparency · Bias & Fairness Testing · Data Handling · Compliance Certifications

This 28-question assessment is used by Pursue SEO Marketing's GRC team to evaluate the AI governance maturity of third-party AI vendors before procurement approval. Each question maps to one or more regulatory frameworks including the EU AI Act, GDPR, NIST AI RMF, and ISO 42001. Questions flagged CRITICAL represent potential blockers to procurement approval. Complete all applicable questions and return to grc@pursueseomarketing.com.

VENDOR INFORMATION

Company Name:		Product Name:	
Contact Name:		Contact Email:	
Assessment Date:		Assessor (Pursue SEO):	

SECTION 01 · VENDOR OVERVIEW

Basic vendor identification, AI product description, and deployment context.

Q1

What is the name of the AI product or feature being assessed, and what business problem does it solve for our organization?

INFO

Guidance: Provide the full product name, version, and specific AI functionality. Be specific about which features use AI/ML versus traditional rule-based logic.

Response:

Q2

What type of AI/ML techniques does this product use? (e.g. LLM, classification model, computer vision, recommendation engine)

MEDIUM

Guidance: Understanding the underlying technique helps classify EU AI Act risk tier and identify relevant bias/fairness concerns.

- | | |
|--|--------------|
| ☐ Large Language Model (LLM / Generative AI) | Notes: _____ |
| ☐ Traditional ML (classification, regression, clustering) | Notes: _____ |
| ☐ Computer Vision / Image Recognition | Notes: _____ |
| ☐ Natural Language Processing (non-generative) | Notes: _____ |
| ☐ Recommendation / Ranking Engine | Notes: _____ |
| ☐ Rule-based / Expert System (not AI/ML) | Notes: _____ |

Q3

Which departments or functions within our organization will interact with or be affected by this AI system?

MEDIUM

Guidance: Identifies scope of impact and which employees, customers, or third parties may be subject to AI-driven decisions.

Response:

Q4

Will this AI system make or significantly influence decisions that materially affect individuals (hiring, credit, healthcare, legal, access to services)?

CRITICAL

Guidance: This is the primary EU AI Act High-Risk trigger. An affirmative answer activates mandatory conformity assessment and human oversight obligations under EU AI Act Annex III.

- | | |
|--|--------------|
| ☐ Yes — directly makes such decisions | Notes: _____ |
| ☐ Partially — significantly influences but human makes final call | Notes: _____ |
| ☐ No — informational/analytical only, no material decisions | Notes: _____ |

SECTION 02 · MODEL TRANSPARENCY

How openly the vendor communicates about how their AI model works, training data, and explainability of decisions.

Q5

Does the vendor provide a Model Card or equivalent documentation describing the model's intended use, limitations, performance metrics, and known failure modes?

HIGH

Guidance: Model Cards are the industry standard for AI transparency. Absence for any high-risk deployment may indicate non-compliance with EU AI Act Art. 13 transparency requirements.

- ☐ Yes — comprehensive Model Card publicly available Notes: _____
- ☐ Partial — some documentation available under NDA Notes: _____
- ☐ No — vendor declines to provide model documentation Notes: _____
- ☐ N/A — rule-based system, no ML model Notes: _____

Q6

Can the vendor explain, in plain language, how the AI system arrives at its outputs or recommendations?

HIGH

Guidance: Explainability is required under GDPR Art. 22, EU AI Act High-Risk requirements, and NIST AI RMF MS-3. Black-box models are non-compliant for high-stakes decisions.

- ☐ Yes — full feature importance and decision reasoning available Notes: _____
- ☐ Partial — general explanation available but not per-decision Notes: _____
- ☐ No — black-box model, no explainability provided Notes: _____

Q7

What data was the model trained on? Does the vendor disclose training data sources, vintage, and any known gaps or limitations?

HIGH

Guidance: Training data quality determines model reliability and bias risk. Required disclosure under EU AI Act Art. 10 (Data Governance).

- ☐ Yes — full disclosure of training data sources and limitations Notes: _____
- ☐ Partial — general description provided without specifics Notes: _____
- ☐ No — training data details are proprietary and undisclosed Notes: _____

Q8

How frequently is the model retrained or updated, and how are customers notified of material changes to model behavior?

MEDIUM

Guidance: Model drift is a critical governance concern. Undisclosed model updates can alter behavior of deployed systems. Required under EU AI Act post-market monitoring obligations.

- ☐ Formal change management — customers notified of all material updates Notes: _____
- ☐ Release notes provided but no proactive customer notification Notes: _____
- ☐ No disclosure process — model updates applied without notice Notes: _____

Q9

Does the vendor publish accuracy, precision, recall, and confidence metrics for the model in production conditions (not just benchmark tests)?

HIGH

Guidance: Benchmark performance often significantly overstates real-world accuracy. Absence of production performance data makes it impossible to assess actual risk.

- ☐ Yes — production performance metrics available and regularly updated Notes: _____
- ☐ Benchmark metrics only — no production performance data Notes: _____
- ☐ No performance metrics disclosed Notes: _____

Q10

Does the vendor provide customers with access to audit logs showing what inputs the AI received and what outputs it produced?

HIGH

Guidance: Audit trail access is required for regulatory investigations and incident response. EU AI Act Art. 19 requires High-Risk AI systems to maintain logs.

- ☐ Yes — full audit logs accessible to customer Notes: _____
- ☐ Partial — logs available on request but not self-service Notes: _____
- ☐ No — audit logs not available to customers Notes: _____

SECTION 03 · BIAS & FAIRNESS TESTING

Whether the vendor has proactively tested for discriminatory outcomes and has controls to detect and remediate bias over time.

Q11

Has the vendor conducted structured bias testing across legally protected characteristics (race, gender, age, disability, national origin) before deployment?

CRITICAL

Guidance: Pre-deployment bias testing is mandatory under EU AI Act for High-Risk systems (Art. 9, 10) and required by EEOC guidance for employment AI in the US.

- ☐ Yes — comprehensive testing with documented results available Notes: _____
- ☐ Partial — some protected characteristics tested but not all Notes: _____
- ☐ No — bias testing has not been conducted Notes: _____
- ☐ N/A — system does not affect individuals covered by anti-discrimination law Notes: _____

Q12	What fairness metrics does the vendor use? (e.g. Demographic Parity, Equal Opportunity, Calibration, Counterfactual Fairness)	HIGH
<i>Guidance: Different fairness metrics can be in mathematical tension. Vendors should document their rationale for which metric they prioritize based on use case context.</i>		
☐	Multiple metrics with documented rationale for selection	Notes: _____
☐	Single metric used — limited fairness perspective	Notes: _____
☐	No formal fairness metrics defined or documented	Notes: _____
☐	N/A — fairness metrics not applicable to this system	Notes: _____
Q13	Does the vendor conduct ongoing bias monitoring in production, not just at initial deployment?	HIGH
<i>Guidance: Bias can emerge over time as real-world usage patterns diverge from training data. Continuous monitoring is required under EU AI Act Art. 72 (post-market monitoring).</i>		
☐	Yes — continuous bias monitoring with automated alerts	Notes: _____
☐	Periodic — scheduled reviews but not continuous monitoring	Notes: _____
☐	No — bias testing conducted at deployment only	Notes: _____
Q14	If bias or discriminatory outcomes are discovered post-deployment, what is the vendor's documented remediation process and timeline?	CRITICAL
<i>Guidance: Vendors must have a clear, contractually enforceable process for addressing discovered bias with specific remediation timelines and escalation paths.</i>		
☐	Formal remediation process with defined SLAs and contractual obligations	Notes: _____
☐	General process described but no contractual SLAs	Notes: _____
☐	No documented bias remediation process exists	Notes: _____
Q15	Can customers configure the AI system's fairness constraints or thresholds to align with their specific regulatory context and risk tolerance?	MEDIUM
<i>Guidance: Different jurisdictions have different fairness requirements. Customer-configurable fairness thresholds demonstrate mature AI governance architecture.</i>		
☐	Yes — fully configurable fairness parameters per customer	Notes: _____
☐	Limited — some parameters configurable within fixed bounds	Notes: _____
☐	No — fixed fairness thresholds applied uniformly to all customers	Notes: _____

Q16

Has the vendor engaged a third-party auditor to independently validate their bias testing results and fairness claims?

HIGH

Guidance: Self-reported bias testing results have inherent conflicts of interest. Independent third-party audits may be required under EU AI Act conformity assessment for High-Risk systems.

- ☐ Yes — third-party audit completed with report available Notes: _____
- ☐ In progress — third-party audit planned or underway Notes: _____
- ☐ No — self-assessed only, no independent validation Notes: _____

SECTION 04 · DATA HANDLING & PRIVACY

How the vendor collects, stores, and protects data — including whether customer data is used to train AI models.

Q17

Does the vendor use customer data (inputs, outputs, interactions) to train, fine-tune, or improve their AI models?

CRITICAL

Guidance: Using customer data to train models without explicit consent violates GDPR and can create confidentiality risks. Must be explicitly addressed in the Data Processing Agreement.

- ☐ No — customer data is never used for model training Notes: _____
- ☐ Only with explicit opt-in consent and anonymization Notes: _____
- ☐ Yes — customer data used for training (opt-out available) Notes: _____
- ☐ Yes — customer data used for training (no opt-out) Notes: _____

Q18

Where is customer data processed and stored? Does the vendor support data residency requirements (e.g. data must remain within the EU or US)?

HIGH

Guidance: GDPR Chapter V restricts transfers of EU personal data to non-adequate third countries. Regulated industries may have contractual or statutory data residency obligations.

- ☐ Customer-configurable data residency with regional processing options Notes: _____
- ☐ Fixed regions available (EU, US) but not fully flexible Notes: _____
- ☐ Data processed in single global region — no residency controls Notes: _____

Q19

Does the vendor execute a Data Processing Agreement (DPA) that covers AI-specific processing activities?

CRITICAL

Guidance: GDPR Art. 28 mandates a DPA for all processors handling personal data. The DPA must explicitly cover AI-specific activities including model training data use and automated decision-making.

- ☐ Yes — comprehensive DPA covering all AI processing activities Notes: _____
- ☐ Standard DPA available but does not specifically address AI activities Notes: _____
- ☐ No DPA offered or available Notes: _____

Q20

What is the vendor's data retention policy for AI inputs, outputs, and logs? Can customers request deletion of their data (right to erasure)?

HIGH

Guidance: GDPR Art. 17 grants individuals the right to erasure. Vendors must be able to delete customer data from AI systems, including from training datasets where applicable.

- ☐ Defined retention limits with self-service customer deletion capability Notes: _____
- ☐ Deletion possible on request but no self-service — takes >30 days Notes: _____
- ☐ Indefinite retention — no deletion capability offered Notes: _____

Q21

Has the vendor documented all sub-processors (third parties) that have access to customer data as part of the AI system's operation?

HIGH

Guidance: AI platforms often rely on third-party model APIs and annotation services. GDPR requires disclosure of all sub-processors and customer notification of material changes.

- ☐ Full sub-processor list publicly available with change notification Notes: _____
- ☐ List available on request but not public — changes not proactively notified Notes: _____
- ☐ Sub-processors not disclosed Notes: _____

Q22

In the event of a data breach involving the AI system, what is the vendor's notification SLA and what evidence of breach investigation will be provided?

CRITICAL

Guidance: GDPR Art. 33 requires breach notification within 72 hours. Vendors must contractually commit to notifying customers within a timeframe that allows them to meet their own regulatory obligations.

- ☐ Contractual notification within 24-48 hours with forensic evidence provided Notes: _____
- ☐ Notification within 72 hours — aligns with GDPR minimum requirement Notes: _____
- ☐ No contractual breach notification SLA defined Notes: _____

SECTION 05 · COMPLIANCE CERTIFICATIONS

Third-party certifications, regulatory compliance evidence, and contractual commitments demonstrating AI governance maturity.

Q23

Does the vendor hold an ISO/IEC 42001 (AI Management System) certification or is certification currently in progress?

HIGH

Guidance: ISO 42001 is the international standard for AI management systems. Certified vendors have undergone independent audit of their AI governance practices.

- ☐ Certified — ISO 42001 certificate available for review Notes: _____
- ☐ In progress — certification audit planned or underway Notes: _____
- ☐ No — not pursuing ISO 42001 certification Notes: _____

Q24

Does the vendor hold a current SOC 2 Type II report? Does the report scope include AI-specific systems and controls?

HIGH

Guidance: SOC 2 Type II provides independent assurance over security controls. Verify the scope explicitly includes the AI system being assessed — older reports may pre-date AI products.

- ☐ Current SOC 2 Type II — scope explicitly includes AI systems Notes: _____
- ☐ SOC 2 Type II exists but AI systems may be out of scope Notes: _____
- ☐ No SOC 2 Type II — SOC 2 Type I only or no report available Notes: _____

Q25

For EU AI Act High-Risk systems — has the vendor completed a conformity assessment and registered the system in the EU AI Act database?

CRITICAL

Guidance: EU AI Act Art. 43 requires conformity assessment for High-Risk AI before EU market placement. Art. 71 requires database registration. Deployers share regulatory exposure under Art. 28.

- ☐ Yes — conformity assessment complete and registered in EU AI database Notes: _____
- ☐ Assessment in progress — expected completion date provided Notes: _____
- ☐ No — conformity assessment not yet initiated Notes: _____
- ☐ N/A — system is not EU AI Act High-Risk Notes: _____

Q26

Does the vendor have a published Responsible AI Policy or AI Ethics Framework that has been endorsed by executive leadership?

MEDIUM

Guidance: Executive-endorsd Responsible AI policies signal organizational commitment to AI governance beyond regulatory compliance.

- ☐ Comprehensive Responsible AI policy — executive signed, publicly available Notes: _____
- ☐ General ethics principles stated but no formal policy document Notes: _____
- ☐ No Responsible AI policy exists Notes: _____

Q27

Does the vendor contractually commit to notifying customers if their AI system's regulatory compliance status changes materially?

HIGH

Guidance: Deployers of third-party AI share regulatory exposure under EU AI Act Art. 28. Contractual protection including notification, remediation timelines, and indemnification rights is essential.

- ☐ Yes — contractual obligation to notify + indemnification clause included Notes: _____
- ☐ Notification obligation only — no indemnification Notes: _____
- ☐ No contractual compliance notification obligations Notes: _____

Q28	Does the vendor provide customers with a human oversight mechanism — can decisions made by the AI system be challenged, reviewed, and overridden by a human?	CRITICAL
-----	--	----------

Guidance: Human oversight is foundational under EU AI Act Art. 14 for High-Risk systems and GDPR Art. 22. The mechanism must be technically implemented and work in practice, not just on paper.

☐
Yes — full override capability with documented override process

Notes: _____

☐
Partial — override possible but requires vendor assistance to implement

Notes: _____

☐
No — AI decisions cannot be overridden within the platform

Notes: _____

SCORING GUIDE & PROCUREMENT DECISION MATRIX

Score Range	Risk Level	Procurement Decision	Next Steps
80–100% + 0 Critical Flags	■ Low Risk	Approved — proceed with standard procurement	Execute DPA · Add to AI inventory · Annual review
60–79% or ≤2 Critical Flags	■ Medium Risk	Conditional — remediation commitments required	Document risk acceptance · GRC sign-off · 6-month reassessment
40–59% or 3–4 Critical Flags	■ High Risk	Escalate — Legal & CISO review required	No contract until flags resolved · Consider alternatives
Below 40% or 5+ Critical Flags	■ Critical Risk	Rejected — do not proceed	Disqualify vendor · Escalate to CISO + Legal immediately

This questionnaire was developed by the GRC team at Pursue SEO Marketing aligned to EU AI Act · GDPR · NIST AI RMF 1.0 · ISO/IEC 42001 · NIST SP 800-53r5 · Classification: CONFIDENTIAL — For procurement and compliance use only.